

S.H.A.D.E. - Problems, Setbacks & Fixes

Review of the proposal PDF, presentation, user blueprint and master blueprint (v2.4.0)

Bottom line. The idea has a strong core: masking Indian PII (Aadhaar, PAN, API keys) before it reaches AI chat tools, then restoring it in the response. The documents wrap that core in five modules, several overclaims and some factual errors. The fixes below are ordered by severity. Items marked *verify* are from my recollection of the law or vendor terms and should be checked against primary sources before you present them.

1. Core mechanism & architecture

#	Problem	Severity	Why it matters	Suggested solution
1	Interception layer is unclear	Critical	A clipboard cannot know its destination. A user-mode listener can only rewrite the clipboard after a copy, not intercept before a paste. 'Kernel interceptor, zero-latency' is inaccurate. The extension, which is the real mechanism, is marked optional.	Make the browser extension (Manifest V3) the primary mechanism, limited to AI chat domains. Treat the clipboard hook as optional. Describe the product as a local companion plus extension.
2	Clipboard masking breaks legitimate use	Critical	People paste Aadhaar and PAN into KYC forms, banking apps and government portals daily. Masking everywhere makes users disable the tool.	Mask only on an allow-list of AI domains. Offer a per-paste 'send real value' override and a warn-mode.
3	Re-hydration has no implementation	Critical	The 'inbound response hook' is not specified. Modern chat UIs use contenteditable inputs and fetch/streaming, not form submits. The /rehydrate endpoint is a function, not a hook.	Specify it: content script rewrites the DOM of rendered responses (MutationObserver) and swaps tokens using the local mapping. Test on real ChatGPT and Claude output before the demo.
4	Mapping lifetime breaks long chats	High	A 15-minute TTL and a per-session flush orphan tokens in old or long conversations.	Key the mapping per chat tab or conversation ID, keep it in memory while the tab lives, and show an 'expired' marker instead of silently failing.
5	Inconsistent token format	High	Documents show both <SYN_AADHAAR_9921> and 'valid-looking 12-digit decoy'.	Choose format-preserving decoys. Recompute a valid check digit, avoid real-number collisions, and match tokens tolerant of spacing and reformatting.
6	Model may alter or drop tokens	High	The LLM can reformat, truncate, translate or split a token, and code transformations can change it.	Normalise before matching (strip spaces and separators), and flag unmatched tokens. Document the known failure cases.
7	Localhost API is open to any web page	High	Any site can call localhost:8000. /rehydrate could expose the vault to a malicious page.	Bind to 127.0.0.1, require a random per-install auth token, lock CORS to the extension origin, and validate Origin headers.
8	Windows Service cannot read the clipboard	Medium	Services run outside the interactive user session.	Run as a user-session tray app, not a Windows Service.
9	Vault description is inconsistent	Low	'Wipes encryption keys' conflicts with a RAM-only vault that has no encryption.	Say simply: held in process memory only, never written to disk or logs.

2. Detection engine (DLP)

#	Problem	Severity	Why it matters	Suggested solution
1	Verhoeff false-positive claim is wrong	Critical	Verhoeff has 10 check digits, so about 1 in 10 random 12-digit strings passes (about 8% with a first digit of 2-9). The docs claim under 0.08% and '99.92% precision'. A judge can disprove it with a barcode.	Remove the claim. Require context (the word Aadhaar or UID nearby, 4-4-4 grouping) and report measured precision and recall on a small labelled test set.

#	Problem	Severity	Why it matters	Suggested solution
2	Verhoeff description errors	Medium	The formula is shown as a sum, but it is an iterative chain $c = d(c, p(i \bmod 8, \text{digit}))$. Verhoeff catches all adjacent transpositions, not 95.4%. The line that Luhn only catches single-digit errors is wrong.	Correct the formula and statistics, or cite a source.
3	Password entropy rule never fires	Medium	Shannon entropy above 3.8 bits per character is mathematically impossible for strings under about 14 characters.	Use a lower threshold plus keyword context (password=, secret=), and exclude hashes, UUIDs and base64 to limit false positives.
4	Only structured identifiers are covered	High	Names, addresses, phone numbers, emails, medical text, client data and proprietary code are missed, giving a false sense of security.	Add phone, email, UPI ID and IFSC patterns, and a small local NER model or Microsoft Presidio for names and addresses. State clearly what is not covered.
5	Coverage gaps by platform	High	Mobile, native apps, file uploads, screenshots and API calls bypass a desktop browser extension.	Add a limitations slide. Scope v1 to desktop Chrome and AI chat sites, and name mobile as roadmap.
6	No evaluation	Medium	No precision, recall or latency measurement.	Build a 100-200 item test set (real-format fakes plus decoys) and show a results table in the deck.

3. Detect module (breach and OSINT)

#	Problem	Severity	Why it matters	Suggested solution
1	HIBP limitations	High	The HIBP breach lookup is per email address and needs a paid API key. It does not cover Aadhaar, PAN or phone numbers. The scan endpoint says 'email_or_phone'.	Support email only. Use the free Pwned Passwords k-anonymity API for typed-in passwords. Label cached fallback data as a demo dataset.
2	Data broker scraper has no real source	High	'14 intelligence registries' and a broker directory are not backed by any real public registry. Scraping brokers is legally and technically risky, and many are offshore.	Drop the scraper claim, or ship a small curated sample list labelled as such.
3	k-anonymity example and claim	Medium	The example hash shown is SHA-1 of the word 'password', not 'MySecret123'. 'Zero information learned' is too strong, since the 5-character prefix leaks a little.	Fix the example hash and say 'minimal information leaked'.
4	Exposome score is arbitrary and inconsistent	Medium	The 26-50 'email only' band is unreachable, since an email scores 5 or 7.5. One leaked password alone scores 60. Demo scores differ across documents (78, 68, 65).	Rename it 'illustrative risk score', align bands to the weights, use one consistent demo value, and do not claim it is validated.
5	Unrealistic breach alert story	Medium	Breaches usually surface days to months later. Showing 'the leaked password' means storing passwords.	Change the story to 'alert when a new breach containing your email is published', and never store passwords.

4. Cloak module (canary tokens and decoys)

#	Problem	Severity	Why it matters	Suggested solution
1	Fake API key cannot trigger an alert	High	Calls to a fake sk-canary key go to OpenAI and return 401, and you never see them.	Use a callback canary (for example a Canarytokens URL or AWS-style token that pings your own endpoint), or remove the claim.
2	'Cryptographic' and '100% proof' overclaim	High	A plus-address is attribution by uniqueness, not cryptography. Tags are easy to strip, and a breach is not the same as a sale.	Say 'leak attribution by unique alias', and describe it as strong evidence, not proof.

#	Problem	Severity	Why it matters	Suggested solution
3	Needs real mail infrastructure	Medium	The @shade.me or @shade.io aliases need a domain, MX and inbound mail handling. Many sites block disposable domains.	Use an existing service (SimpleLogin, Addy, Gmail plus-addressing) for the demo, or mark Cloak as roadmap.
4	Indian KYC and OTP flows block fake identities	Medium	Many Indian services need a real phone or Aadhaar. Decoy identities there can amount to fraud.	Scope decoys to low-trust sign-ups only, and add an explicit 'do not use for KYC or financial services' note.
5	Module has no file or owner	Medium	Module 3 is absent from the project tree and the 24-hour work split.	Cut it from the build and keep it as one roadmap slide.

5. Enforce module (DPDP legal notices)

#	Problem	Severity	Why it matters	Suggested solution
1	Penalty claim is misstated	Critical	As I recall, the Rs.250 Cr cap applies to failure to maintain reasonable security safeguards. Penalties for general non-compliance are lower. The docs say it applies to 'ignoring deletion requests'. <i>Verify against the Act's Schedule.</i>	Quote the exact penalty for the exact breach. Use security-safeguard failure for the Rs.250 Cr figure.
2	Section references look wrong	High	The docs cite Section 33 and Section 13 for a Board complaint. As I recall, Section 13 is grievance redressal with the fiduciary, and the Board route is under a different provision. 'Section 12(3)' wording also needs checking. <i>Verify.</i>	Quote the Act directly, with a legal reviewer or a faculty member signing off.
3	30-day countdown is not from the Act	Medium	Response timelines come from the Rules, not the Act. As I recall, the Rules were notified in late 2025 with a phased commencement. <i>Verify.</i>	Check which provisions are in force today before saying 'enforce', and cite the Rules for any timeline.
4	Hallucination risk in 'verified legal clauses'	High	A small local model (Phi-3) or even Gemini can invent citations.	Use fixed templates with statutory text hard-coded. The model fills fields only (names, company, dates).
5	'Dispatch', 'certified' and 'cryptographic receipt' are impossible	High	Opening a mailto: link sends nothing, so there is no Message-ID and no proof of dispatch.	Say 'generates a ready-to-send draft'. If you want proof, send via the Gmail API and record the real Message-ID.
6	Legal limits of erasure	Medium	Retention is exempt where law requires it (banks, telecom, KYC). Offshore brokers may be outside reach. Fiduciaries may demand identity proof. There is no public grievance-officer directory.	Add these as stated limitations. Ship a small curated list of 10-20 fiduciaries with verified grievance contacts.
7	Verification challenge parser reads the inbox	Medium	Parsing broker replies needs inbox access, which conflicts with the privacy pitch.	Make it opt-in, read-only, label-scoped, and processed locally. Or drop it for v1.

6. Voice module

#	Problem	Severity	Why it matters	Suggested solution
1	Porcupine licence	Medium	As I recall, the free tier is non-commercial, and custom wake words have time-limited keys. This cost is not in the business model. <i>Verify current terms.</i>	Fine for the hackathon. For a product, budget a licence or use an open alternative (openWakeWord).

#	Problem	Severity	Why it matters	Suggested solution
2	Unsourced performance claims	Low	'Zero false triggers', '220 ms transcription', '<2% CPU' and 'sub-50 ms wake' are not measured.	Measure on your machine, or remove the numbers.
3	Noisy hall and accent risk	Medium	Vosk small-model accuracy drops with Indian accents and noise.	Keep the click-chips fallback, and use a fixed command grammar to improve recognition.
4	Windows-only stack	Low	SAPI5 TTS and the .ppn file are Windows-specific.	State 'Windows demo' explicitly. Do not claim cross-platform.
5	Positioning as 'Siri or JARVIS'	Medium	Judges will compare against Siri and Gemini, and S.H.A.D.E. understands only fixed commands. Voice does not provide interception.	Pitch voice as a hands-free control layer on a privacy engine.

7. Trust & privacy claims

#	Problem	Severity	Why it matters	Suggested solution
1	'Zero-knowledge' and 'verifiable via network logs'	Critical	Canary mail, HIBP lookups, Gemini drafting (user and company names) and broker reply parsing all send data off-device. 'Zero-knowledge' also has a specific cryptographic meaning that does not apply.	Publish a table: local-only features (DLP) versus network features, with exactly what leaves the device in each. Replace 'zero-knowledge' with 'local-first'.
2	Trust paradox	High	A tool that reads every paste and prompt is itself a high-value target. The vault is a honeypot for malware.	Open-source the DLP core, keep the vault in memory only, add a visible pause switch, and add a short threat model.
3	You become a data fiduciary or processor	Medium	Handling user identity data and documents creates your own DPDP obligations.	Collect the minimum, keep processing on-device, and add a privacy notice slide. Note it as a compliance step before launch.

8. Business & market

#	Problem	Severity	Why it matters	Suggested solution
1	Unsourced statistics	High	'85% of employees', '99.9% never exercise rights', '100+ zombie accounts', 'gone forever' and 'permanently logged' have no sources.	Cite a source for each, or rephrase to qualitative claims. Retention and training use depend on provider and plan.
2	91.6% margin and benchmark claim	High	Margin counts only API COGS, not support, payment fees, hosting or acquisition. Snowflake, CrowdStrike and Datadog run at roughly 70-80% gross margin, so '91.6% matches them' is wrong.	Present 'estimated API cost per user' only, and drop the named-company comparison.
3	Aggressive financial targets	High	Break-even at Month 4, 8 SME pilots converting in Year 1 and Rs.6.2 Cr in Year 2 have no stated assumptions. The Rs.12 L for 200 seats is compared to a Rs.250 Cr fine that does not apply to this use.	Show assumptions in a small table, or replace projections with a validation plan (pilot users, waitlist).
4	Willingness to pay	High	Rs.299 per month is steep for Indian consumers, and the harm is invisible. Enterprises can block AI tools or use enterprise plans with no-training terms.	Target Indian developers and small IT or fintech teams first. Test a lower consumer price and a per-team plan.
5	Platform risk and competition	High	OpenAI, Google and Microsoft can add redaction. Purview, Nightfall, Cyberhaven, Presidio, DeleteMe and Incogni already exist and are not mentioned.	Add a competition slide. Differentiate on India-specific detection, local-first design and re-hydration.
6	'Zero acquisition cost' for the API channel	Low	Partnerships with VPN and antivirus vendors are slow and costly.	Remove the claim and defer the B2B2C channel.

#	Problem	Severity	Why it matters	Suggested solution
7	Bypass by users	Medium	Employees can use a personal phone or another browser.	Be honest that it prevents accidental leaks, not deliberate ones.

9. Demo & presentation

#	Problem	Severity	Why it matters	Suggested solution
1	Demo does not prove interception	Critical	Pasting into your own sandbox only shows regex working. Judges will ask for a real ChatGPT or Claude round trip.	Demo live in the browser: paste, see masked text sent, see the response restored. Record a backup video.
2	Invites judges to paste real Aadhaar	High	Real IDs in a hackathon prototype is a privacy risk and sets a poor example.	Provide valid-checksum test numbers and say so on screen.
3	Mocked pieces are not labelled	High	The scan, score and broker nodes are mock or cached data, and judges will ask what is real.	Add a 'real vs simulated' slide and tag demo screens with a 'demo data' badge.
4	'Ciphertext' wording	Low	Tokenization is not encryption.	Use 'tokenized' or 'masked' throughout.
5	Name sounds like malware	Medium	'Synthetic Host for Automated Data Extractor' reads like an exfiltration tool.	Keep the name SHADE but re-expand it, for example 'Secure Host for AI Data Exposure'.
6	Inconsistent UI description	Low	Light-mode 'clean' and 'cyberpunk' are both used.	Pick one.
7	Slides are text-heavy	Low	Slides 1, 3 and 7 are walls of bullets. No architecture diagram or screenshot.	Add one architecture diagram and one real screenshot. Cut bullets by half.

10. Scope & 24-hour feasibility

#	Problem	Severity	Why it matters	Suggested solution
1	Too much for 24 hours	Critical	Five modules, five endpoints, a voice daemon, an extension and a React HUD are not credible at about 1,000 lines. The extension has no owner.	Build deep on two pillars: Prevent (extension plus re-hydration plus detection) and Enforce (template notice). Detect via HIBP only. Make Cloak and voice stretch goals.
2	Feature creep dilutes the pitch	High	Prevent is a DLP product, Detect and Cloak are breach monitoring, Enforce is legal tech.	Pitch one product: a local privacy layer for AI use, with voice control and takedown drafts as extras.
3	Team split leaves the core unowned	High	Student 1 covers backend only, and nobody owns the extension or DOM re-hydration.	Reassign: one person on extension and re-hydration, one on detection engine, one on notice templates and UI, one on voice, pitch and testing.

Recommended fix order

1	Decide the mechanism: Chrome extension on AI domains, with local companion and token-secured localhost API.
2	Implement real re-hydration and test on live ChatGPT and Claude responses.
3	Fix claims judges can disprove: Verhoeff precision, canary API key, DPDP penalty and section numbers, 'dispatch' and 'cryptographic receipt'.
4	Replace 'zero-knowledge' with a table of what is local and what leaves the device.
5	Add context rules, extra identifiers (phone, email, UPI, IFSC) and a small measured test set.
6	Switch notices to fixed templates, and verify which DPDP provisions are in force.
7	Cut scope: Detect via real HIBP only, Cloak and voice as roadmap or stretch.
8	Rewrite the business slide with sourced numbers and stated assumptions. Add competition, limitations and 'real vs simulated' slides.
9	Prepare the live demo with test numbers, a backup video and the click-chip fallback.

What is genuinely strong: an India-specific, deterministic, offline-capable PII masker with reversible substitution for AI chat, plus a templated DPDP erasure draft. Both are narrow, demoable and differentiated. Everything else should support these two or wait.